

-



- Single Sign-On

On this page

Single Sign-On

Was this page helpful? 

Single Sign-On (**SSO**) is a functionality that allows users to access various applications (*i.e.* to start a session) by signing in to only one of the applications. This eliminates the need for users to set different passwords as well as to sign in to each application individually.

Another component associated with this functionality is allowing users to sign out from all the applications at once (*i.e.* without having to sign out individually from all the applications). This component is commonly referred to as Single Logout (**SLO**).

SSO in Pulse is done using Security Assertion Markup Language (SAML) as the protocol to authenticate and optionally authorize users that are provisioned by an external Identity Provider.

Introduction to SAML

SAML is an XML-based open standard for exchanging user authentication and authorization information between security domains. The primary use case of SAML is to enable **SSO**, which increases security, allows practical access to multiple applications and decreases administrative time and costs relative to the traditional option of signing in to each application individually.

SAML uses security tokens that contain assertions to communicate user information between a SAML authority, referred to as Identity Provider (IdP), and a SAML consumer, referred to as Service Provider (SP). At a high level, the IdP is the asserting party which is responsible for managing the identity information of users and to provide the information in form of tokens to the SPs. The SP corresponds to an application that requires user authentication to start an active session. The SP constitutes the relying party because it allows the user to sign in based on the information provided by the IdP. Note that the SP is not responsible for managing user credentials and does not even have access to the user password.

SSO in Pulse using SAML 2.0

SAML 2.0 is the current version supported by Pulse. In the context of **SSO** integration through SAML, Pulse acts as the SP, and the IdP is the server in which the user has an account and the user credentials are stored. There is a number of ways in which the IdP can be configured to manage user information, one of which is by a self-hosted Active Directory Federation Services (AD FS) server.

AD FS is a service provided by Microsoft as a standard role for Windows Server that provides web sign in using existing Active Directory (AD) credentials. In the case of **SSO** implemented in Pulse, the IdP of choice is AD FS; however, any other standard-compliant IdP service may be used instead (Pulse is agnostic to the implementation). Since the implementation of SAML is not dedicated to Pulse, Feedzai's Clients may have already a SAML architecture implemented before acquiring any of the Feedzai's products.

Regarding SSO, Pulse has two different types of users:

- **Non-SSO Users:** These users are created and their information is managed inside Pulse. They also [sign in using a Pulse form](#).
- **SSO Users:** External users that are able to [sign in into Pulse by using an external page](#) which is managed by the IdP. Depending on how the user **authorization** is configured in Pulse, **SSO Users** can be handled in two distinct ways:
 - If authorization is configured to be managed by the IdP (default behaviour), users can be created only by the **automatic user provisioning**. When a new user signs in for the first time, it does not exist as a **Pulse User** (i.e. is not yet manually configured in Pulse). This Pulse user is created on-the-fly after being authorized by the IdP. The user credentials and additional user information are managed by the IdP which communicates with Pulse to provide user authentication and authorization.
 - If authorization is explicitly configured to be managed by Pulse, SSO users can login only after they are created in Pulse. In this case, user authorization (roles, groups, etc) is entirely managed in Pulse, and the IdP manages only the authentication.

Learn more about [user provisioning](#) in Pulse.

Scenarios of SSO in Pulse

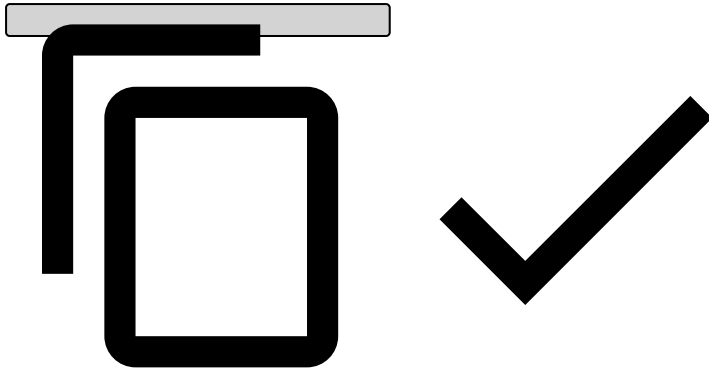
There is currently one supported scenario of **SSO** using SAML, namely the **SP-initiated** configuration.

In this case, when a user opens a Pulse URL, and is not already signed in, they are redirected to a URL that is managed by the IdP. In this IdP URL, the user is prompted with a sign-in form, and after being authenticated, they are automatically redirected back to the Feedzai URL. The user is then signed in to the application that they were accessing in the first place (i.e. Pulse URL) as well as to all the other applications that are configured as SPs.

More on SP-initiated configuration

Consider the scenario in which the user browses to a Pulse URL that they have saved as a bookmark, or was sent by email. E.g.:

```
http://pulseviews/management/#apps/datasciencedemo/datascience
```



The following steps explain sign in via SP-initiated:

1. User opens the Pulse URL.
2. The user is redirected to the URL of the IdP, which is configured in Pulse, by sending a SAML authentication request.
3. If the user does not have an active session, the user is prompted with a sign in form that is configured by the IdP and requires authentication (e.g. username and password).
4. The IdP builds the SAML authentication response in the form of XML containing the user's username and/or email address as well as other optional [provisioning data](#), signs it using an X.509 certificate, and sends the information to Pulse. Pulse retrieves the authentication response and validates it using the certificate fingerprint. The user is now signed in to Pulse.

Note that, if the user is already signed in when opening the Pulse URL (i.e. Step 1), Steps 2 and 4 still apply; however, the user is not prompted with the sign in form mentioned in Step 3. The user might notice the address bar flicking as a result of Steps 2 and 4, but no further interaction is required.

Learn more about [sign in via SP-initiated in Pulse](#).

User Provisioning

Depending on how Pulse is configured, user authorization settings can be managed by the IdP (default behavior) or by Pulse.

External authorization (using IdP)

Automatic user provisioning is a mandatory component of Pulse SSO for external authentication. It is the concept of creating users on-the-fly at the first time that they sign in without being previously created as Pulse Users. In the case of SSO Users, provisioning is the only option to create users, since they cannot be manually created using the Pulse UI first, and after configured as SSO Users. When an SSO User signs, Pulse updates its information regarding the referred user. User provisioning is done through a SAML assertion that is sent by the IdP to the SP. This assertion contains attributes that can be configured in IdP service of choice. The assertion can be used to send additional information beyond the user identity (i.e. username) which Pulse will map to the correspondent configurations in the User Settings. This includes **Full Name**, **Language**, **Groups**, **Roles**, and **Tenants**.

Internal authorization

If Pulse is set up to use internal authorization, then SSO users need to be created both in the IdP and in Pulse. That means that an IdP user is authorized to access Pulse only if a user with the same identifier is created in Pulse. The authorization properties of that user (roles, groups) are managed in Pulse, as with normal users. In this case, there is no need to configure authorization settings in IdP since it will be ignored by Pulse.

Sign out

Sign out is performed by the **SLO** component. Similarly to the sign in requests, the sign out comprises a LogoutRequest and a LogoutResponse.

Pulse supports sign out via **SP-initiated** - a user signs out from one of the SPs.

There are different ways to implement the SP-initiated sign-out; for example, the application can initiate the LogoutRequest to the IdP. The IdP communicates with all the SPs to sign out all the active sessions without requiring further user interaction. The SPs reply back with a LogoutResponse.

Session Management

According to the SAML 2.0 specification, there is an attribute that may be included in the assertion named `SessionNotOnOrAfter`. This attribute corresponds to the time instant, encoded in UTC, at which the IdP and the SP sessions must be considered ended.

This is an optional attribute that can be added to the SAML assertion. If the attribute is not included, the time for the session to end is set by the same logic Pulse uses for Non-SSO user sessions. When the session is expired, the user can sign in via SP-initiated and continue the work at the point that was left when the session was expired.

Learn More

To expand your knowledge on the SSO functionality, visit the following pages:

- [Sign in via SP-initiated in Pulse](#)
- [Signing in as Pulse Administrator](#)
- [Configuring AD FS](#)